

Web Application Security Assessment Report

Mediroza General Hospital

Assessment Type: Web Application Security Assessment

Target: <https://medirozahospital.com>

Assessment Date: 27 September 2026

Testing Environment: Kali Linux

Application Technology Observed: PHP 8.2.33, LiteSpeed Web Server

Application Generator: Mediroza CMS 1.4.2

1. Executive Summary

A security assessment was performed against the Mediroza General Hospital web application to identify publicly accessible resources, exposed application components, authentication behavior, directory listings, backup files, and information disclosure.

During the assessment, several security weaknesses were identified. The most significant finding was the public exposure of an internal database backup through the `/old/` directory. The backup file was directly downloadable without authentication and contained staff and shareholder information.

The exposed database backup contained sensitive staff records including names, job titles, departments, email addresses, telephone numbers, national identification numbers, salaries, and joining dates. It also contained shareholder names, ownership percentages, number of shares, and share classes.

The assessment also identified directory listing enabled on `/old/` and `/patient/`. The patient directory listing disclosed application files including `download.php`, `error_log`, `login.php`, `logout.php`, and `portal.php`.

Access to the patient reports directory itself was denied with HTTP status `403 Forbidden`, and direct access to the patient portal without authentication resulted in an HTTP `302` redirect to the login page.

No successful authentication bypass or unauthorized access to patient reports was demonstrated during the testing performed.

2. Scope

The assessment focused on the publicly accessible Mediroza General Hospital web application.

The following areas were examined:

- Main website
 - `/patient/` directory
 - `/patient/login.php`
 - `/patient/portal.php`
 - `/patient/download.php`
 - `/patient/reports/`
 - `/patient/error_log`
 - `/staff/login.php`
 - `/old/`
 - `/old/mediroza_db_backup_2019.sql`
 - `/robots.txt`
 - `/sitemap.xml`
-

3. Methodology

The assessment followed a controlled, evidence-based web application testing approach.

The following activities were performed:

1. Website reconnaissance
2. HTTP response and header inspection
3. Directory and resource discovery
4. Examination of `robots.txt`
5. Examination of `sitemap.xml`
6. Identification of publicly accessible directories
7. Identification of exposed backup files
8. Analysis of the exposed database backup
9. Inspection of patient authentication functionality
10. Authentication behavior testing using invalid test credentials
11. Examination of access controls on protected patient resources
12. Collection of evidence for reporting

Testing was limited to the resources and requests demonstrated during the assessment.

4. Reconnaissance Findings

4.1 Technology Disclosure

The login pages disclosed the following information:

Mediroza CMS version:

Mediroza CMS 1.4.2

The HTTP response from the login application also disclosed:

X-Powered-By: PHP/8.2.33

The web server identified itself as:

LiteSpeed

Security Impact

Technology and version disclosure can provide useful information to an attacker during reconnaissance. It allows an attacker to identify the technologies used by the application and potentially research known weaknesses associated with those technologies.

Evidence

The staff login page contained:

```
<meta name="generator" content="Mediroza CMS 1.4.2">
```

The patient login page contained the same CMS disclosure.

HTTP responses included:

x-powered-by: PHP/8.2.33

and:

server: LiteSpeed

5. Finding M1: Information Disclosure Through robots.txt

Description

The website's `robots.txt` file disclosed several directories that are intended to be restricted from search engine indexing.

The following entries were identified:

```
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/
```

The file also disclosed the sitemap location.

Evidence

The following content was obtained from `/robots.txt`:

```
User-agent: *  
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/
```

Sitemap: <https://medirozahospital.com/sitemap.xml>

Security Impact

`robots.txt` is not an access-control mechanism. Disclosing sensitive or administrative paths in the file can make those paths easier to discover during reconnaissance.

In this case, the disclosed `/old/` path led to a directory containing a database backup.

Recommendation

Sensitive directories should not rely on `robots.txt` for protection.

The following should be implemented:

- Remove sensitive paths from publicly accessible web directories.
- Restrict sensitive resources through server-side access controls.
- Prevent indexing of internal resources.
- Ensure backup files cannot be accessed through the web server.

6. Finding M2: Publicly Accessible Database Backup

Severity: Critical

Description

A database backup file was found publicly accessible through:

`/old/mediroza_db_backup_2019.sql`

The `/old/` directory itself was also accessible and displayed directory contents.

The database backup could be retrieved directly without authentication.

Evidence

Request:

`GET /old/mediroza_db_backup_2019.sql`

Response:

HTTP/2 200
content-type: text/x-sql
content-length: 6346
server: LiteSpeed

The file contained:

`-- mediroza_db_backup_2019.sql`

```
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
```

This demonstrates that the exposed file was explicitly identified as an internal database backup containing confidential records.

Directory Listing Evidence

The `/old/` directory returned:

Index of `/old/`

and exposed:

`mediroza_db_backup_2019.sql`

The directory listing showed the file size as approximately 7 KB.

Database Structure

The backup contained at least two database tables:

`staff`
`shareholders`

This was confirmed using:

```
grep -iE 'CREATE TABLE|INSERT INTO' recon/mediroza_db_backup_2019.sql
```

Output:

```
CREATE TABLE `staff` (  
INSERT INTO `staff` ...  
CREATE TABLE `shareholders` (  
INSERT INTO `shareholders` ...
```

Exposed Staff Information

The `staff` table contained fields including:

- ID
- Full name
- Job title
- Department
- Email
- Phone
- National ID
- Monthly salary
- Date joined

The backup contained 30 staff records.

Example database structure:

```
CREATE TABLE `staff` (  
  `id` int(11) NOT NULL AUTO_INCREMENT,  
  `full_name` varchar(120) NOT NULL,  
  `job_title` varchar(120) NOT NULL,  
  `department` varchar(80) NOT NULL,  
  `email` varchar(120) NOT NULL,  
  `phone` varchar(20) NOT NULL,  
  `national_id` varchar(20) NOT NULL,  
  `monthly_salary_zar` int(11) NOT NULL,  
  `date_joined` date NOT NULL,  
  PRIMARY KEY (`id`)  
)
```

Exposed Shareholder Information

The `shareholders` table contained:

- Shareholder ID
- Shareholder name
- Share percentage
- Shares held
- Share class

Example structure:

```
CREATE TABLE `shareholders` (  
  `id` int(11) NOT NULL AUTO_INCREMENT,  
  `name` varchar(120) NOT NULL,  
  `share_percentage` float(10,2) NOT NULL,  
  `shares_held` int(11) NOT NULL,  
  `share_class` varchar(20) NOT NULL,  
  PRIMARY KEY (`id`)  
)
```

```
`id` int(11) NOT NULL AUTO_INCREMENT,  
`shareholder_name` varchar(120) NOT NULL,  
`share_percent` decimal(5,2) NOT NULL,  
`shares_held` int(11) NOT NULL,  
`share_class` varchar(20) NOT NULL,  
PRIMARY KEY (`id`)  
)
```

The backup contained 10 shareholder records.

Security Impact

This is a significant confidentiality breach.

An unauthenticated internet user could obtain sensitive organizational and personal information without compromising an account.

The exposed information could potentially support:

- Identity theft
- Social engineering
- Phishing
- Targeted attacks against employees
- Employee impersonation
- Organizational reconnaissance
- Financial or business intelligence gathering

The exposure of national identification numbers and salary information increases the sensitivity of the finding.

Root Cause

The database backup appears to have been stored inside a publicly accessible web directory:

/old/

Directory listing was enabled, and no effective access restriction prevented direct retrieval of the SQL file.

Recommendation

Immediate remediation is required.

1. Remove the database backup from the public web directory.
2. Store backups outside the web root.
3. Disable directory listing.
4. Review all historical backup files.
5. Search the entire web root for `.sql`, `.bak`, `.zip`, `.tar`, `.gz`, and similar backup files.
6. Restrict backup storage using appropriate server permissions.
7. Rotate or invalidate credentials if any authentication secrets are discovered in backups.
8. Assess whether exposed personal information requires incident-response or regulatory action.
9. Review web-server configuration to prevent accidental exposure of backup files.

7. Finding M3: Directory Listing and Application File Disclosure

Severity: High

Description

Directory listing was enabled for the patient application directory.

Request:

GET /patient/

Response:

HTTP/2 200

The server returned:

Index of /patient/

The following application resources were disclosed:

/patient/reports/
/patient/download.php
/patient/error_log
/patient/login.php

/patient/logout.php
/patient/portal.php

Evidence

The following links were extracted from the directory listing:

href="/patient/reports/"
href="/patient/download.php"
href="/patient/error_log"
href="/patient/login.php"
href="/patient/logout.php"
href="/patient/portal.php"

Security Impact

Directory listing provides attackers with information about the application's internal structure.

It can reveal:

- Application functionality
- Authentication endpoints
- Download functionality
- Report storage locations
- Error logs
- Session-related endpoints
- Potentially sensitive files

The disclosure of `error_log` is particularly concerning because logs can sometimes contain sensitive application information.

In this assessment, direct access to the error log was denied with HTTP `403 Forbidden`, which prevented retrieval of its contents.

Recommendation

Disable directory indexing for application directories.

Sensitive application files should not be directly exposed through directory listings.

Server configuration should prevent users from browsing directories such as:

/patient/
/staff/
/old/

Only explicitly intended resources should be accessible.

8. Patient Reports Access Control

8.1 Reports Directory

The following request was performed:

GET /patient/reports/

The server returned:

HTTP/2 403

with:

403 Forbidden

Access to this resource on the server is denied!

This indicates that direct unauthenticated directory access was denied.

8.2 Patient Portal

The following request was performed:

GET /patient/portal.php

The server returned:

HTTP/2 302

location: login.php

This indicates that unauthenticated access to the patient portal redirected the requester to the login page.

Assessment Result

Based on the tests performed, direct unauthenticated access to the patient portal was not demonstrated.

Similarly, direct access to the reports directory returned **403 Forbidden**.

These results should be documented as successful access-control observations rather than vulnerabilities.

9. Patient Login Testing

The patient login form was inspected.

The form uses:

```
method="POST"  
action="login.php"
```

The input fields were:

```
username  
password
```

A controlled invalid test was performed using:

```
username=testuser  
password=testpassword
```

The server returned the login page with the message:

Username not found

Security Observation

The application distinguishes an invalid username condition by returning:

Username not found

This may provide information about whether a submitted username exists.

However, during the assessment performed, no systematic username enumeration was conducted and no valid account was accessed.

Therefore, the finding should be recorded as an authentication-information disclosure observation rather than claiming successful account enumeration.

Recommendation

Authentication failure messages should use a generic message such as:

Invalid username or password.

The application should avoid revealing whether the username or password was specifically incorrect.

Additional recommended controls include:

- Rate limiting
- Account lockout or progressive delays
- Monitoring of repeated failed authentication attempts
- Multi-factor authentication where appropriate

10. Staff Login Application

The staff login endpoint was identified at:

/staff/login.php

The page disclosed:

Staff Login
Internal staff access only.

The form uses:

method="POST"

action="login.php"

with:

username

password

The page also disclosed:

Mediroza CMS 1.4.2

No successful staff authentication was demonstrated during the assessment.

11. Patient Application Resources

The following resources were identified through the publicly accessible patient directory:

Resource	Observation
/patient/login.php	Patient authentication page
/patient/portal.php	Redirects unauthenticated users to login
/patient/download.php	Redirects unauthenticated users to login
/patient/logout.php	Logout endpoint exposed through directory listing
/patient/reports/	Returns HTTP 403
/patient/error_logging	Returns HTTP 403
/patient/	Directory listing enabled

The presence of these resources demonstrates that directory indexing exposes the application's internal structure even where individual resources implement access controls.

12. HTTP Security Observations

The assessment observed the following response information.

Server

LiteSpeed

PHP

PHP/8.2.33

CMS

Mediroza CMS 1.4.2

Session Cookie

The patient login application issued a PHP session cookie:

PHPSESSID

The observed cookie included the **Secure** attribute.

The assessment did not establish whether all recommended cookie attributes, such as **HttpOnly** and **SameSite**, were consistently configured

13. Sitemap Analysis

The website's sitemap was accessible at:

/sitemap.xml

It listed:

/index.html

/about.html

/doctors.html

/contact.html

The sitemap did not list the patient, staff, or old directories.

However, these resources remained discoverable through other mechanisms, including `robots.txt` and directory listing.

14. Findings Summary

ID	Finding	Severity	Status
M1	Sensitive directory disclosure through <code>robots.txt</code>	Low	Confirmed
M2	Publicly accessible database backup containing confidential records	Critical	Confirmed
M3	Directory listing exposing patient application resources	High	Confirmed
M4	Technology/version disclosure	Low	Confirmed
M5	Login response reveals "Username not found"	Medium	Observed
M6	Unauthenticated portal access redirected to login	Positive control	Confirmed
M7	Patient reports directory denied unauthenticated access	Positive control	Confirmed
M8	Patient download endpoint redirects unauthenticated users	Positive control	Confirmed

15. Risk Assessment

Critical Risk

Public Database Backup

The database backup is the most significant finding because it was directly accessible without authentication and contained confidential staff and shareholder information.

The exposure is not limited to application metadata. It includes structured personal and organizational information.

High Risk

Patient Directory Listing

The patient directory exposes multiple application components.

Although individual protected resources returned access-control responses during testing, directory listing unnecessarily exposes the application's structure and potentially sensitive endpoints.

Medium Risk

Authentication Error Disclosure

The login system returned:

Username not found

This behavior may assist username enumeration.

Further controlled testing would be required to establish the practical extent of enumeration.

Low Risk

Technology Disclosure

The application disclosed CMS, PHP, and web-server information.

This provides useful reconnaissance information but was not demonstrated to directly provide unauthorized access.

16. Evidence Collected

The following evidence files were collected during the assessment:

```
recon/homepage.html
recon/https-headers.txt
recon/staff-login.html
recon/patient-login.html
recon/patient-login-current.html
recon/patient-error-log.txt
recon/old.html
recon/sitemap.xml
recon/mediroza_db_backup_2019.sql
recon/exposed-backup-evidence.txt
recon/exposed-backup-headers.txt
recon/login-test.txt
```

These files preserve the relevant responses and extracted information used during the assessment.

17. Remediation Plan

Priority 1: Remove Exposed Database Backup

Immediately remove:

```
/old/mediroza_db_backup_2019.sql
```

from the publicly accessible web root.

Backups should be stored outside the web root and protected using appropriate file-system and access controls.

Priority 2: Disable Directory Listing

Disable directory indexing for:

/patient/
/staff/
/old/

The server should return an appropriate access-denied response rather than an automatically generated directory listing.

Priority 3: Protect Sensitive Files

Review the web root for:

*.sql
*.bak
*.backup
*.zip
*.tar
*.gz
error_log

Any sensitive files discovered should be removed from public access.

Priority 4: Review Exposed Personal Information

Because the backup contains personal and financial information, the organization should determine:

- What information was exposed
- How long it was publicly accessible
- Whether the information was accessed by unauthorized parties
- Whether affected individuals need to be notified
- Whether applicable data-protection requirements apply

Priority 5: Improve Authentication Error Messages

Replace:

Username not found

with a generic authentication failure message:

Invalid username or password.

This reduces the amount of information disclosed to unauthenticated users.

Priority 6: Reduce Technology Disclosure

Review whether the following information needs to be publicly exposed:

Mediroza CMS 1.4.2

PHP/8.2.33

LiteSpeed

Where practical, unnecessary version information should be removed from HTTP responses and HTML metadata.

18. Retesting Recommendations

After remediation, the following tests should be repeated:

1. Request `/old/`.
2. Request the exposed SQL backup directly.
3. Request `/patient/`.
4. Request `/staff/`.
5. Request `/patient/reports/`.
6. Request `/patient/error_log`.
7. Request `/patient/download.php`.
8. Test unauthenticated access to `/patient/portal.php`.
9. Test authentication failure messages.
10. Search for additional backup files.
11. Confirm that directory indexing has been disabled.
12. Confirm that sensitive files return an appropriate denial or not-found response.

The SQL backup should no longer be retrievable from the public internet.

19. Conclusion

The assessment identified multiple security weaknesses in the Mediroza General Hospital web application.

The primary security issue was the public exposure of an internal SQL database backup through the `/old/` directory. The backup contained confidential staff and shareholder records, including personal identification, contact, employment, salary, and ownership information.

The patient application also exposed its directory structure through directory indexing. Although direct unauthenticated access to the patient portal and reports directory was not demonstrated, the directory listing disclosed several application endpoints.

The assessment also identified information disclosure through `robots.txt`, technology/version information, and authentication error messages.

No successful authentication bypass or unauthorized access to patient reports was demonstrated during the testing performed.

The highest priority should be removal of the exposed database backup, disabling directory listing, reviewing all publicly accessible backup files, and assessing the exposure of the confidential information contained within the backup.